

Security+ 2.3 · Cloud-specific Vulnerabilities

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — Cloud-specific Vulnerabilities (4:06)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Cloud-specific vulnerabilities include DoS with billing (generates high costs — attacker doesn't take down the service, just makes it expensive); authentication bypass (open API/exploit); directory traversal (accessing files outside allowed scope). The biggest cloud risk is MISCONFIGURATION (open bucket, permissive IAM). Shared responsibility: provider secures the cloud; customer secures what's in the cloud.

High-Yield Core Concepts Tested on Exam

- Open S3 bucket = the #1 cloud data leak
- Shared responsibility: provider = OF the cloud; customer = IN the cloud
- Defense: CSPM (checks configuration), least-privilege IAM
- Cloud DoS can be financial (billing) rather than availability
- Directory traversal can expose cloud storage files

Exam Tips & Classic Scenarios

- 'misconfigured bucket exposes data' = cloud misconfig (the #1 failure)
- 'client is responsible for securing data IN the cloud' = shared responsibility
- 'attacker increases cloud costs' = cloud-specific DoS (billing)

Typical Exam Scenario: Scenario: 'a company stores customer data in a public S3 bucket due to a configuration error' = misconfiguration (the most common cloud failure).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Cloud-specific Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **CSPM:** Cloud Security Posture Management: Continuous automated compliance and misconfiguration auditing platform for cloud infrastructure (IaaS/PaaS).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In the SHARED RESPONSIBILITY model, who handles the PHYSICAL security of the datacenter?

- A) The customer
- B) The cloud provider
- C) Both equally
- D) An external auditor

2. In the AWS shared responsibility model, the customer is NOT responsible for:

- A) Data encryption
- B) Hypervisor patches
- C) Security group configuration
- D) Identity management

3. Protecting data 'at rest' means encrypting:

- A)** Network traffic
- B)** Data written to storage/disk
- C)** The user's password
- D)** The source code

4. The service that controls WHO can access WHAT in the cloud (users, roles, permissions) is:

- A)** CDN
- B)** IAM
- C)** VPN
- D)** DNS

5. Corporate scenario (Cloud-specific Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Open S3 bucket = the #1 cloud leak'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Open S3 bucket = the #1 cloud leak...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Cloud-specific Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Shared responsibility: provider = OF the cloud; customer = IN the cloud'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Shared responsibility: provider = OF the cloud; customer = IN the cloud...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Cloud-specific Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Defense: CSPM (checks config), IAM with least privilege'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Defense: CSPM (checks config), IAM with least privilege...
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Cloud-specific Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'misconfigured bucket exposes data' = cloud misconfig (the #1 failure). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'misconfigured bucket exposes data' = cloud misconfig (the #1 failure)
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Cloud-specific Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'client is responsible for securing data IN the cloud' = shared responsibility'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'client is responsible for securing data IN the cloud' = shared responsibility...

10. Corporate scenario (Cloud-specific Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: a company stores customer data in a public S3 bucket due to a configuration error' = misconfiguration (the most common failure in cloud). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'company stores customer data in a public S3 bucket due to a configuration error' = misconfiguration (the most common failure in cloud).
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — The cloud provider.

✓ **Why it is correct:** In the cloud computing shared responsibility model, the physical security of the datacenter — including facility access control, video surveillance, redundant power, climate control, fire prevention and suppression, and protection against natural disasters — is the exclusive responsibility of the cloud provider. CompTIA Security+ SY0-701 emphasizes that the provider is always responsible for 'security OF the cloud' (the underlying infrastructure), while the customer is responsible for 'security IN the cloud' (their data, configurations, identities, and applications). The customer has no physical access to the datacenter and therefore cannot implement physical controls; the responsibility is non-transferable and not shared in this specific aspect.

✗ **Why the others are wrong:**

- *The customer:* The customer is responsible for security IN the cloud, i.e., their data, access configurations, encryption of their information, identity management, and patching of their instances. However, they do not have physical access to the provider's datacenter and cannot install locks, cameras, or fire suppression systems. Assigning physical security to the customer would violate the shared responsibility model, as they do not control the physical environment. The question specifically asks about the PHYSICAL security of the datacenter, which is the provider's exclusive domain.
- *Both equally:* Shared responsibility is not divided equally in all aspects. It is segmented by layers: the provider handles physical security, virtualization infrastructure, and the underlying network; the customer handles the security of their data, applications, and identities. The physical security of the datacenter is a layer the customer cannot operate or directly audit, so there is no equal sharing. Saying both are equally responsible for physical security is technically incorrect and contradicts the model defined by CompTIA and major cloud providers (AWS, Azure, GCP).
- *An external auditor:* An external auditor performs independent compliance assessments, such as SOC 2, ISO 27001, or PCI DSS certifications, but does not execute the physical security of the datacenter. They verify whether the controls implemented by the provider are adequate, but they are not responsible for operating them. Auditing is a verification function, not an operational one. Therefore, assigning physical security to an external auditor confuses the oversight role with the execution role, which is a serious conceptual error in the context of the shared responsibility model.

2) B — Hypervisor patches.

✓ **Why it's correct:** The correct answer is 'Hypervisor patches'. In the AWS shared responsibility model, security 'of' the cloud is AWS's responsibility, while security 'in' the cloud is the customer's. AWS manages the physical infrastructure, network, hosts, and virtualization layer, including the hypervisor (Xen, Nitro, etc.). Patching the hypervisor is an exclusive AWS activity, as the customer does not have access to that layer. The customer is responsible for encrypting data, configuring security groups, and managing identities (IAM), but never for updating the hypervisor.

✗ **Why the others are wrong:**

- *Data encryption:* Data encryption is the customer's responsibility in the shared responsibility model. The customer decides whether to encrypt data at rest and in transit, manages keys (in the case of SSE-C or KMS with customer-managed keys), and configures encryption policies. AWS provides the mechanisms, but implementation and management are the customer's. Therefore, the customer IS responsible for data encryption, and the alternative is incorrect in stating otherwise.
- *Security group configuration:* Security groups are virtual firewalls that control inbound and outbound traffic to instances. Configuring these rules is entirely the customer's responsibility, who

must define which ports, protocols, and sources/destinations are allowed. AWS only provides the service; misconfiguration can expose resources. Thus, the customer IS responsible for configuring security groups, and the alternative is wrong.

- *Identity management*: Identity management (IAM) in AWS is the customer's responsibility. The customer creates users, groups, roles, policies, and credentials, and defines who can access which resources. AWS manages the IAM service infrastructure, but identity configuration and governance are the customer's. Therefore, the customer IS responsible for identity management, and the alternative does not correspond to the requested exception.

3) B — Data written to storage/disk.

✓ **Why it's correct:** Protecting data 'at rest' means encrypting data stored on disk, storage, databases, backups, or any persistence medium. Encryption at rest ensures that even if the physical medium is stolen or improperly accessed, the data remains unreadable without the decryption key. In CompTIA Security+ SY0-701, this concept is covered as part of protecting data in different states: at rest, in transit, and in use. The correct answer refers specifically to data written to storage/disk, which is the exact definition of 'at rest'.

✗ Why the others are wrong:

- *Network traffic*: Encrypting network traffic refers to protecting data 'in transit', using protocols such as TLS, IPsec, or SSH. This protects communication between systems, but not stored data. The question asks about data 'at rest', which is a distinct state. Therefore, this alternative describes a different concept and does not answer the prompt.

- *The user's password*: Encrypting the user's password is a credential protection practice, typically done using hash functions (such as bcrypt, Argon2) and not reversible encryption. Additionally, a password is just a specific type of data, not encompassing the broad concept of data 'at rest'. Password protection is a subset of data security, but does not define what it means to protect data at rest.

- *The source code*: Source code is a type of data that can be at rest, in transit, or in use. Encrypting it would be a specific application of protection at rest, but it is not the general definition of the term. This alternative improperly restricts the concept to a single type of data, while the question seeks the broad and correct definition of 'data at rest', which encompasses any data stored on disk.

4) B — IAM.

✓ **Why it is correct:** IAM (Identity and Access Management) is the service that manages identities, authentication, and authorization in the cloud. It controls WHO can access WHAT by defining users, groups, roles, permission policies, and access conditions. In the CompTIA Security+ SY0-701 syllabus, IAM is presented as the pillar for applying the principle of least privilege, separation of duties, and multifactor authentication. Services like AWS IAM, Azure AD (Entra ID), and Google Cloud IAM allow creating granular policies that specify allowed or denied actions on specific resources, making it the exact answer for cloud access control.

✗ Why the others are wrong:

- *CDN*: CDN (Content Delivery Network) is a geographically distributed network of servers to deliver static and dynamic content with low latency, such as images, videos, and files. It improves performance and availability but does not manage identities, roles, or permissions. It does not control who accesses what; it only optimizes content delivery. Therefore, it is completely inapplicable to the logical access control problem described in the question.

- *VPN*: VPN (Virtual Private Network) establishes an encrypted tunnel to protect communication between a device and a network, ensuring confidentiality and integrity of traffic. Although it can be used as part of a secure remote access strategy, it does not define who can access which resources

in the cloud. The VPN authenticates the tunnel but does not manage granular permissions on services and data. Access control to specific resources is the function of IAM, not VPN.

- **DNS:** DNS (Domain Name System) translates domain names into IP addresses, enabling the location of services on the internet. It is fundamental for name resolution but has no relation to authentication, authorization, or identity management. It does not control who accesses what; it only resolves names. Confusing DNS with IAM is a categorical error, as they operate at completely different layers of the OSI and security models.

5) B — Implement the corresponding solution: Open S3 bucket = the #1 cloud leak....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cloud-specific Vulnerabilities): Open S3 bucket = the #1 cloud leak. Misconfigured S3 buckets with public access are a common cause of data breaches in cloud environments.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Shared responsibility: provider = OF the cloud; customer = IN the cloud....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cloud-specific Vulnerabilities): Shared responsibility: provider = OF the cloud; customer = IN the cloud. This means the cloud provider is responsible for the security OF the cloud (e.g., physical infrastructure, hypervisor, network), while the customer is responsible for security IN the cloud (e.g., data, applications, identity management, configurations). Understanding this division is critical for properly allocating security controls and avoiding gaps.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: Defense: CSPM (checks config), IAM with least privilege....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cloud-specific Vulnerabilities): Defense: CSPM (checks config), IAM with least privilege.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'misconfigured bucket exposes data' = cloud misconfig (the #1 failure).

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cloud-specific Vulnerabilities): 'misconfigured bucket exposes data' = cloud misconfig (the #1 failure). Misconfigured cloud storage buckets are a leading cause of data breaches.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'client is responsible for securing data IN the cloud' = shared responsibility....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cloud-specific Vulnerabilities): 'client is responsible for securing data IN the cloud' = shared responsibility.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) C — Implement the corresponding solution: Scenario: 'company stores customer data in a public S3 bucket due to a configuration error' = misconfiguration (the most common failure in cloud)..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cloud-specific Vulnerabilities): Scenario: 'company stores customer data in a public S3 bucket due to a configuration error' = misconfiguration (the most common failure in cloud). This is a cloud-specific vulnerability where improper configuration exposes data; the appropriate control is to implement the corresponding solution, such as enforcing private bucket policies, using

configuration management, and continuous monitoring.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.